

Threat Modeling Report

Created on 10-Mar-26 4:16:03 PM

Threat Model Name:

Owner:

Reviewer:

Contributors:

Description:

Assumptions:

External Dependencies:

Threat Model Summary:

Not Started	0
Not Applicable	0
Needs Investigation	22
Mitigation Implemented	0
Total	22
Total Migrated	0

Diagram: Diagram 1

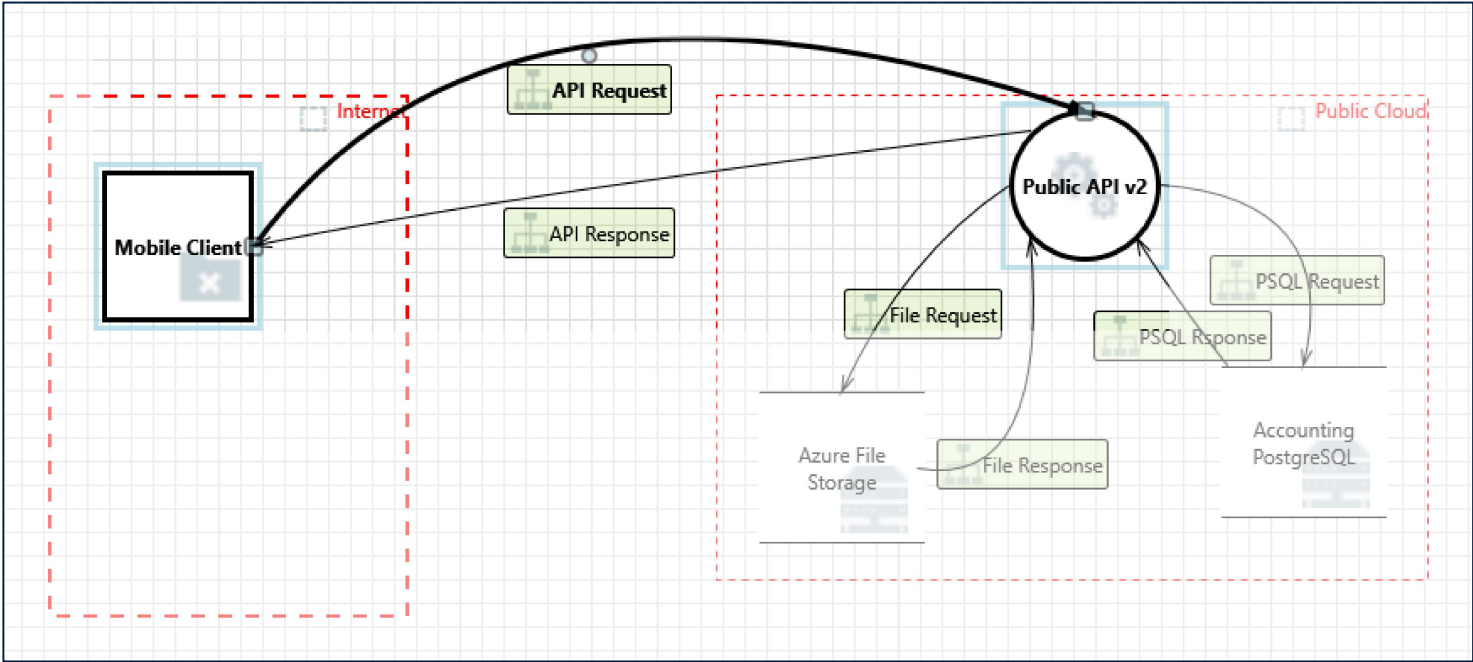
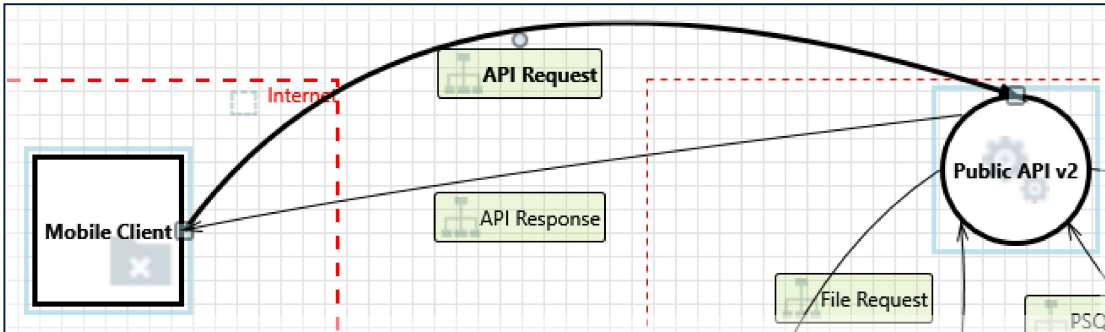


Diagram 1 Diagram Summary:

Not Started	0
Not Applicable	0
Needs Investigation	22
Mitigation Implemented	0
Total	22
Total Migrated	0

Interaction: API Request



1. Cross Site Request Forgery [State: Needs Investigation] [Priority: High]

Category: Elevation Of Privilege

Description: Cross-site request forgery (CSRF or XSRF) is a type of attack in which an attacker forces a user's browser to make a forged request to a vulnerable site by exploiting an existing trust relationship between the browser and the vulnerable web site. In a simple scenario, a user is logged in to web site A using a cookie as a credential. The user then browses to web site B. Web site B returns a page with a hidden form that posts to web site A. Since the browser will carry the user's cookie to web site A, web site B now can take any action on web site A, for example, adding an admin to an account. The attack can be used to exploit any requests that the browser automatically authenticates, e.g. by session cookie, integrated authentication, IP whitelisting, ... The attack can be carried out in many ways such as by luring the victim to a site under control of the attacker, getting the user to click a link in a phishing email, or hacking a reputable web site that the victim will visit. The issue can only be resolved on the server side by requiring that all authenticated state-changing requests include an additional piece of secret payload (canary or CSRF token) which is known only to the legitimate web site and the browser and which is protected in transit through SSL/TLS. See the Forgery Protection property on the flow stencil for a list of mitigations.

Justification: Cross-site request forgery attacks could trick an authenticated Mobile Client into sending unauthorized API requests to Public API v2, performing actions on behalf of the victim without their knowledge.

2. Elevation by Changing the Execution Flow in Public API v2 [State: Needs Investigation] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into Public API v2 in order to change the flow of program execution within Public API v2 to the attacker's choosing.

Justification: The Web Server (Public API v2) may be exploited to impersonate the Mobile Client context and gain unauthorized elevated access to backend resources.

3. Public API v2 May be Subject to Elevation of Privilege Using Remote Code Execution [State: Needs Investigation] [Priority: High]

Category: Elevation Of Privilege

Description: Mobile Client may be able to remotely execute code for Public API v2.

Justification: Mobile Client requests could be crafted to exploit vulnerabilities in Public API v2, allowing an attacker to escalate privileges and gain unauthorized access to sensitive system functions.

4. Elevation Using Impersonation [State: Needs Investigation] [Priority: High]

Category: Elevation Of Privilege

Description: Public API v2 may be able to impersonate the context of Mobile Client in order to gain additional privilege.

Justification: Public API v2 may be exploited by an attacker impersonating a privileged Mobile Client context to gain elevated access to restricted backend resources and administrative functions.

5. Data Flow API Request Is Potentially Interrupted [State: Needs Investigation] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: An external agent could overwhelm the API Request data flow channel with excessive traffic, exhausting network resources and preventing legitimate Mobile Client requests from reaching Public API v2.

6. Potential Process Crash or Stop for Public API v2 [State: Needs Investigation] [Priority: High]

Category: Denial Of Service

Description: Public API v2 crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: Public API v2 could crash under a flood of malformed or excessive API requests, causing complete service unavailability for all Mobile Client users and disrupting business operations.

7. Data Flow Sniffing [State: Needs Investigation] [Priority: High]

Category: Information Disclosure

Description: Data flowing across API Request may be sniffed by an attacker. Depending on what type of data an attacker can read, it may be used to attack other parts of the system or simply be a disclosure of information leading to compliance violations. Consider encrypting the data flow.

Justification: Data flowing across the API Request channel could be intercepted by a network-level attacker if TLS encryption is not enforced, exposing sensitive user credentials and session tokens.

8. Potential Data Repudiation by Public API v2 [State: Needs Investigation] [Priority: High]

Category: Repudiation

Description: Public API v2 claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Public API v2 could deny having received specific API requests from the Mobile Client without proper request logging and audit trails, making it impossible to verify or dispute transactions.

9. Potential Lack of Input Validation for Public API v2 [State: Needs Investigation] [Priority: High]

Category: Tampering

Description: Data flowing across API Request may be tampered with by an attacker. This may lead to a denial of service attack against Public API v2 or an elevation of privilege attack against Public API v2 or an information disclosure by Public API v2. Failure to verify that input is as expected is a root cause of a very large number of exploitable issues. Consider all paths and the way they handle data. Verify that all input is verified for correctness using an approved list input validation approach.

Justification: Data transmitted from the mobile client could be intercepted and modified in transit if proper encryption (TLS) is not enforced on the API request channel.

10. Spoofing the Mobile Client External Entity [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Mobile Client may be spoofed by an attacker and this may lead to unauthorized access to Public API v2. Consider using a standard authentication mechanism to identify the external entity.

Justification: A malicious actor could impersonate a legitimate mobile client by forging requests to the Public API v2, bypassing authentication controls.

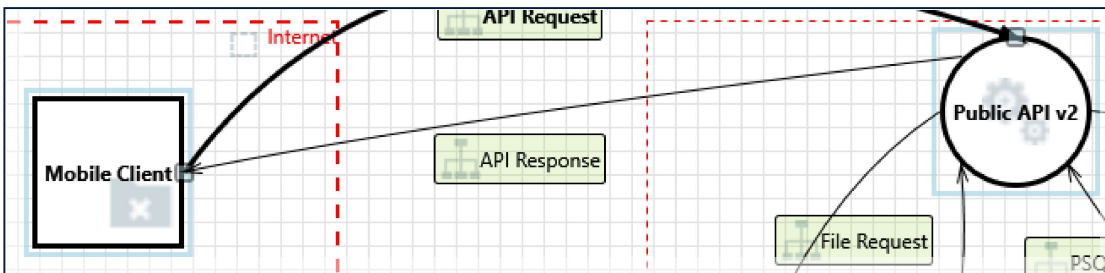
11. Spoofing the Public API v2 Process [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Public API v2 may be spoofed by an attacker and this may lead to information disclosure by Mobile Client. Consider using a standard authentication mechanism to identify the destination process.

Justification: A malicious actor could impersonate the Public API v2 endpoint, intercepting requests from the Mobile Client and returning fraudulent responses to steal credentials or session data.

Interaction: API Response



12. Data Flow API Response Is Potentially Interrupted [State: Needs Investigation] [Priority: High]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: An external agent could flood the API response channel with excessive requests, overwhelming the Mobile Client or the API layer and causing legitimate responses to be delayed or dropped entirely.

13. External Entity Mobile Client Potentially Denies Receiving Data [State: Needs Investigation] [Priority: High]

Category: Repudiation

Description: Mobile Client claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Without proper logging and audit trails on API responses, the Mobile Client could deny receiving specific responses, making it impossible to verify transactions or trace malicious activity.

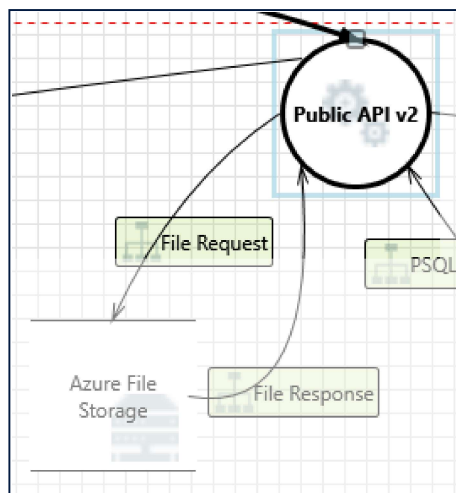
14. Spoofing of the Mobile Client External Destination Entity [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Mobile Client may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Mobile Client. Consider using a standard authentication mechanism to identify the external entity.

Justification: A malicious actor could intercept the API response and spoof the identity of the Public API v2, tricking the Mobile Client into accepting fraudulent data as legitimate server responses.

Interaction: File Request



15. Potential Excessive Resource Consumption for Public API v2 or Azure File Storage [State: Needs Investigation] [Priority: High]

Category: Denial Of Service

Description: Does Public API v2 or Azure File Storage take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification: Public API v2 could be exploited to send excessive file requests to Azure File Storage, exhausting storage bandwidth and making legitimate file operations unavailable to the system.

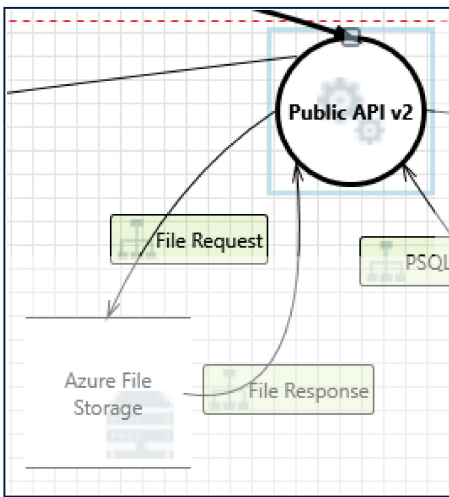
16. Spoofing of Destination Data Store Azure File Storage [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Azure File Storage may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Azure File Storage. Consider using a standard authentication mechanism to identify the destination data store.

Justification: Azure File Storage destination could be spoofed, redirecting file requests to a malicious storage endpoint and causing sensitive files to be written to or retrieved from an unauthorized location.

Interaction: File Response



17. Weak Access Control for a Resource [State: Needs Investigation] [Priority: High]

Category: Information Disclosure

Description: Improper data protection of Azure File Storage can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification: Improper data protection on file responses may expose sensitive files to unauthorized parties if access controls between Azure File Storage and the API layer are misconfigured or absent.

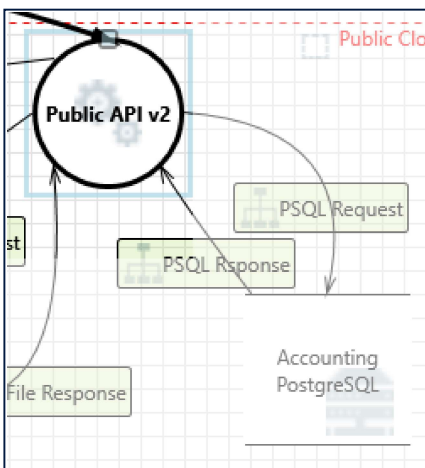
18. Spoofing of Source Data Store Azure File Storage [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Azure File Storage may be spoofed by an attacker and this may lead to incorrect data delivered to Public API v2. Consider using a standard authentication mechanism to identify the source data store.

Justification: Azure File Storage responses could be spoofed by a malicious process returning tampered or malicious file content to the Public API v2, potentially compromising data integrity across the system.

Interaction: PSQL Request



19. Potential Excessive Resource Consumption for Public API v2 or Accounting PostgreSQL [State: Needs Investigation] [Priority: High]

Category: Denial Of Service

Description: Does Public API v2 or Accounting PostgreSQL take explicit steps to control resource consumption? Resource consumption attacks can be hard to deal with, and there are times that it makes sense to let the OS do the job. Be careful that your resource requests don't deadlock, and that they do timeout.

Justification: Public API v2 could be exploited to send excessive PSQL queries to the Accounting PostgreSQL database, exhausting connection pools and causing denial of service to legitimate database operations.

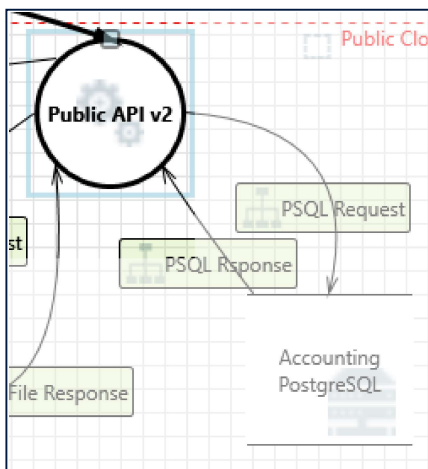
20. Spoofing of Destination Data Store Accounting PostgreSQL [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Accounting PostgreSQL may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Accounting PostgreSQL. Consider using a standard authentication mechanism to identify the destination data store.

Justification: An attacker could redirect PSQL requests to a rogue database by spoofing the Accounting PostgreSQL destination, causing sensitive data to be written to or read from an unauthorized data store.

Interaction: PSQL Response



21. Weak Access Control for a Resource [State: Needs Investigation] [Priority: High]

Category: Information Disclosure

Description: Improper data protection of Accounting PostgreSQL can allow an attacker to read information not intended for disclosure. Review authorization settings.

Justification: Improper data protection on PSQL responses may expose sensitive accounting records to unauthorized parties if access controls between the database and API layer are not properly enforced.

22. Spoofing of Source Data Store Accounting PostgreSQL [State: Needs Investigation] [Priority: High]

Category: Spoofing

Description: Accounting PostgreSQL may be spoofed by an attacker and this may lead to incorrect data delivered to Public API v2. Consider using a standard authentication mechanism to identify the source data store.

Justification: Accounting PostgreSQL responses could be spoofed by a malicious process impersonating the database, returning falsified financial data to the Public API v2 and corrupting business logic.